

Data Security: Risks, Threats & Vulnerabilities Vulnerabilities Assessment Assessment

Claudiu Brandas, Prof. PhD.
claudiu.brandas@e-uvt.ro

West University of Timisoara,
Faculty of Economics and Business Administration,
Department of Finance, Information Systems and Business Modeling



<https://www.linkedin.com/in/claudiu-brandas-92651145>



Objectives



Understand Data Lifecycle Security

Gain comprehensive knowledge of the various stages in stages in the data lifecycle and the unique security implications each stage presents to your organization.



Vulnerabilities Assessment

Acquire skills to evaluate security risks in data management for effective mitigation.

(MITRE ATT&CK Framework)



Identify Security Concerns

Learn to recognize specific risks, threats, and vulnerabilities that can compromise data integrity, confidentiality, and availability at each lifecycle stage.



Defend Against Data Breaches

Explore advanced strategies to safeguard against unauthorized **data exfiltration** and **SQL injection attacks, attacks**, ensuring the integrity and confidentiality of your of your data.

Some Facts on Data Breach

VERIZON > 2025 Data Breach Investigations Report

<https://www.verizon.com/business/resources/reports/dbir/>

IBM > Cost of a Data Breach Report 2025

<https://www.ibm.com/reports/data-breach>

Some Facts on Data Breach

SolarWinds Supply Chain Attack (2020)

Incident: Attackers inserted malicious code into SolarWinds' Orion software software updates, compromising data integrity in government and corporate corporate networks.

Impact: Affected 18,000+ organizations, including U.S. federal agencies, highlighting highlighting risks in software supply chains.

<https://www.fortinet.com/resources/cyberglossary/solarwinds-cyber-attack>



Risks

Potential for loss or damage due to exploited vulnerabilities, requiring systematic assessment and prioritization to effectively manage organizational impact.



Threats

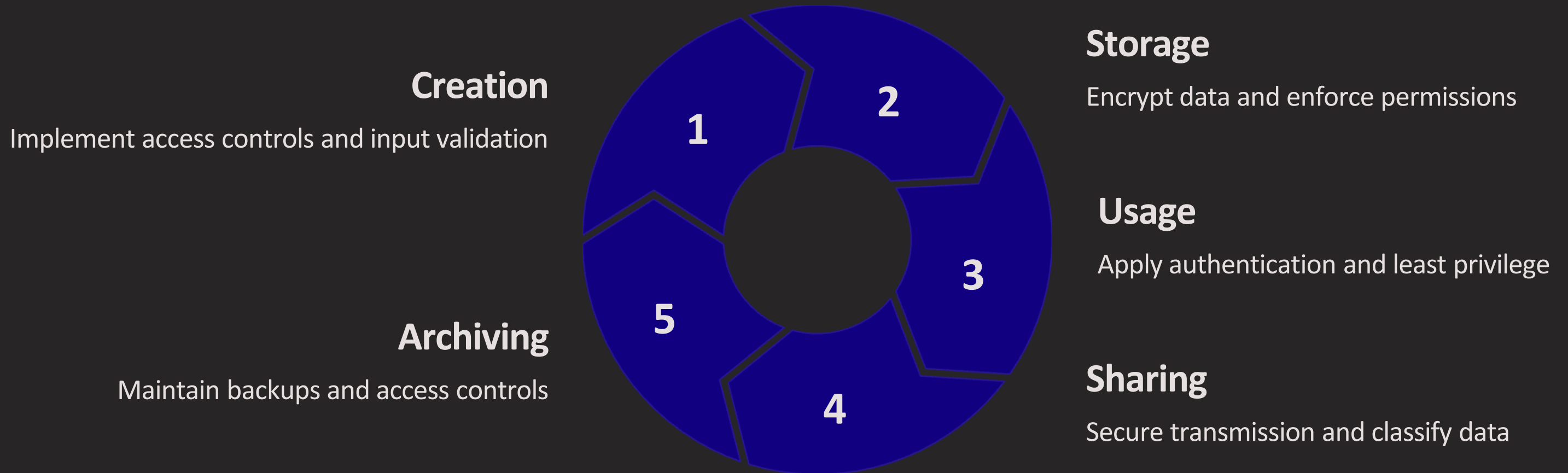
Entities or events that can cause harm, including malicious actors like hackers, as well as natural disasters and system failures that can compromise data security.



Vulnerabilities

Weaknesses that that threats can exploit, such as weak passwords, passwords, unpatched systems, or insufficient access access controls, creating potential potential entry points for attacks. attacks.

Data Lifecycle Security



Each stage of the data lifecycle presents unique security challenges. At creation, unauthorized data entry and injection attacks threaten integrity. During storage, data breaches and insider threats pose significant risks. Usage requires protection against unauthorized access and exfiltration.

When sharing data, man-in-the-middle attacks and interception become concerns. Archiving faces risks of data degradation and unauthorized retrieval.

Data Creation Security

Securing the origin

The stage where data is generated or collected (e.g., via web forms, IoT devices, devices, or APIs).

Primary Threats

- Hackers intercepting data.
- Insecure collection methods (e.g., unencrypted forms).

Critical Vulnerabilities

- Lack of encryption during data capture (e.g., no HTTPS).
- Insufficient input validation on forms or APIs.
- Weak authentication mechanisms.

Mitigation Strategies

- Implement strong encryption
- Implement strong validation

Data Usage Security

Description

Data is accessed and processed by users and applications, necessitating controls to prevent misuse or leakage.

Primary Threats

- Unauthorized access
- Data exfiltration
- Privilege escalation

Critical Vulnerabilities

- Weak authentication
- Insecure APIs
- Lack of least privilege enforcement

Mitigation Strategies

- Use strong authentication (e.g., two-factor authentication).
- Secure APIs with proper validation and encryption.
- Apply the principle of least privilege.

Data Storage Security

Storage Environments

S Data resides in databases, cloud systems, and physical media.

Each environment presents unique security challenges requiring tailored protections.

Primary Threats

- Data breaches from external attackers
- Malicious insider activities
- Physical theft of storage media

Critical Vulnerabilities

- Insufficient or outdated encryption
- Inadequate backups and monitoring
- Overly permissive access settings

Mitigation Strategies

Implement strong encryption for all sensitive data.

Backup policy

Conduct regular audits and access reviews.

GAMIFICATION 4 Cybersecurity Education

Data Leak



<https://cybergamesuk.com/data-leak>





MITRE ATT&CK Framework

A comprehensive guide to cybersecurity's most powerful threat intelligence framework.

 attack.mitre.org



MITRE ATT&CK®

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is...



Overview

Introduction

What is MITRE ATT&CK and why it matters

1

2

Framework Structure

Core components and matrices

Case Study

3

4

Student Exercise

Hands-on application of the framework

Mapping a Cyberattack with Data Exfiltration and SQL Injection



Introduction to MITRE ATT&CK

What Is It?

A globally recognized knowledge base of adversary tactics and techniques built from real-world observations.

Purpose

Documents how adversaries operate through tactics, techniques, and procedures (TTPs).

Why It Matters

Focuses on the adversary's perspective to help defenders anticipate and counter attacks effectively.

Introduction to MITRE ATT&CK

MITRE ATT&CK stands for **MITRE Adversarial Tactics, Techniques, and Common Knowledge**. It was developed by The MITRE Corporation, a not-for-profit organization that operates federally funded research centers.

Origin

Created in 2013 by Mitre Corporation as an internal project to document cyber adversary behavior.

Impact

Transformed threat intelligence by standardizing how we document, share, and respond to cyber threats.

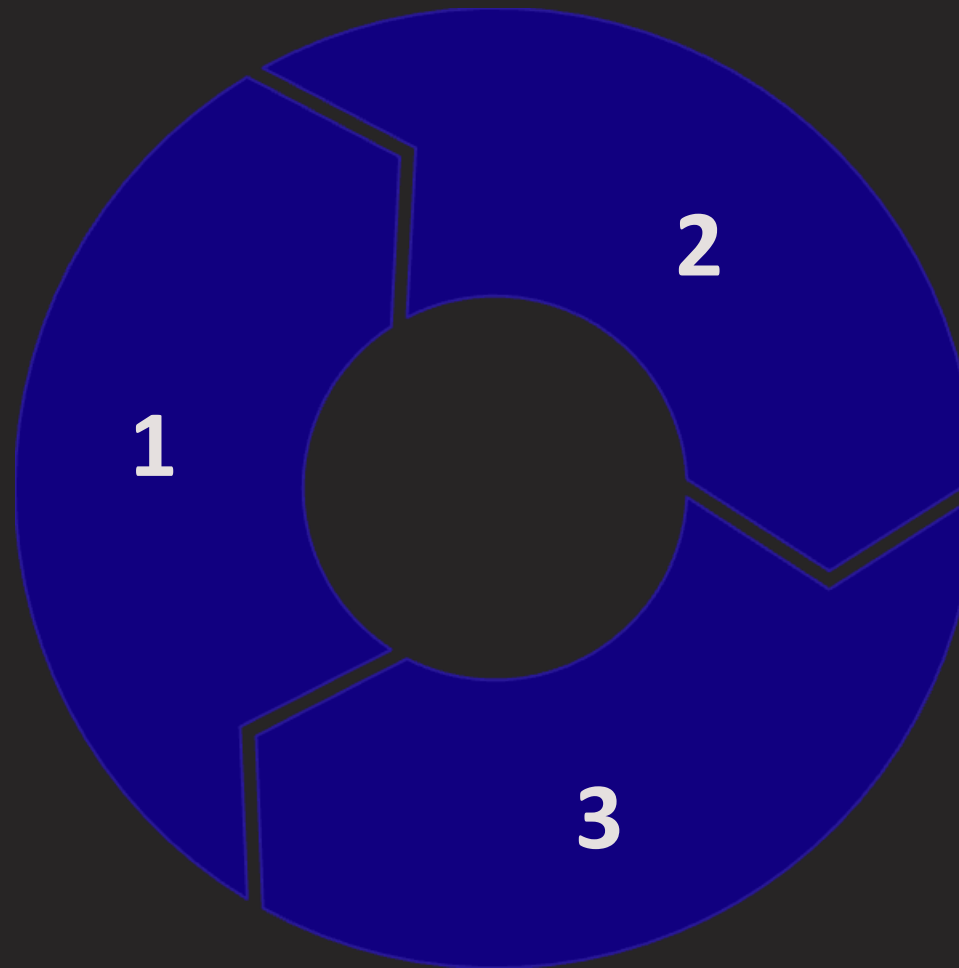
Evolution

Publicly released in 2015, now maintained by a global community of cybersecurity professionals.

Real-World Applications

Threat Detection

Security teams spot techniques like data exfiltration exfiltration in networks.



Red Teaming

Attack simulation teams mimic real adversaries using the framework.

Gap Analysis

Organizations check if defenses cover all ATT&CK techniques.

Structure of the Framework

Tactics

The "why" of an attack—attack—goals like Initial Access, Persistence, or Exfiltration.

Related to

Risks and Threats

Techniques

The "how"—specific methods, such as Phishing Phishing or Credential Dumping.

Related to

Vulnerabilities Assessment

Matrices

Enterprise (Windows, Mac, Mac, Linux), Mobile (Android, iOS), and ICS (industrial control systems). systems).

Structure of the Framework

Data Source

include data components, which identify specific properties/values of a data source relevant to detecting a given ATT&CK technique or sub-technique.

Related to **Vulnerabilities**

Detection

Strategies for TTP's and "HOW TO" detect Threats and Vulnerabilities.

Related to
Vulnerabilities Assessment

Mitigations

WHAT Preventive or Detective Controls should be implemented.

Related to **Controls**



Why Use ATT&CK in Cybersecurity Education?

1

Standardized Language

Offers a common vocabulary for discussing threats across the industry.

2

Adversarial Thinking

Encourages students to think like attackers, improving their defensive skills.

3

Practical Skills

Prepares students for real-world roles in threat detection and response.

Key Concepts



Adversary Behavior

Emphasizes what adversaries do after gaining access, such as stealing data (data exfiltration).



Living Framework

Updated regularly with new threat intelligence to stay relevant to evolving cyber threats.



Community-Driven

Contributions from researchers, practitioners, and organizations worldwide keep it robust.



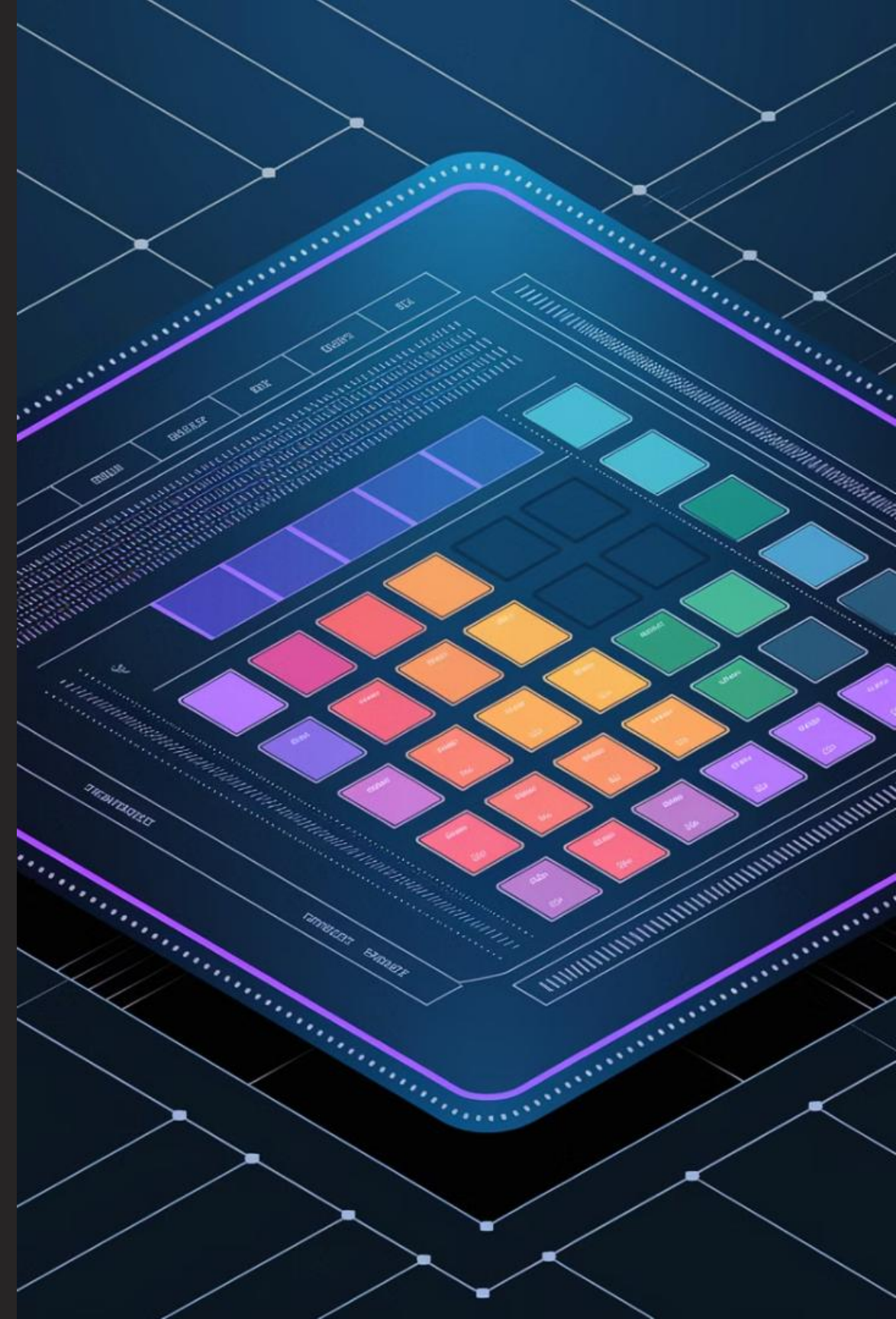
MITRE ATT&CK TTP's flow

MITRE ATT&CK - Flow							
Mapping:	MITRE ATT&CK flow (Tactics, Techniques, Procedures, Mitigation, Detection, Data sources) for data exfiltration from mysql database with sql injection						
Team/Individual:	Claudiu Brandas						
Tactics	Techniques	Procedures	Mitigation	Detection	Data sources		
TA0001	T1190	G0087	M1016	DS0015	DS0040		

MITRE ATT&CK® Navigator



mitre-attack.github.io





Exercises:

- Get the file [mitre_attck_mapping_flow.xlsx](#) or use the Navigator
- Choose one of the following and complete the file with:
 - Mapping a flow for data exfiltration from one drive
 - Mapping a flow for data exfiltration from google drive
 - Mapping a flow for data exfiltration from ms sql server
 - Mapping a flow for data exfiltration from cloud
- Upload your exercise file in your folder on Teams

MITRE ATT&CK Extensions



D3FEND > A knowledge graph of cybersecurity countermeasures

countermeasures

<https://d3fend.mitre.org/>

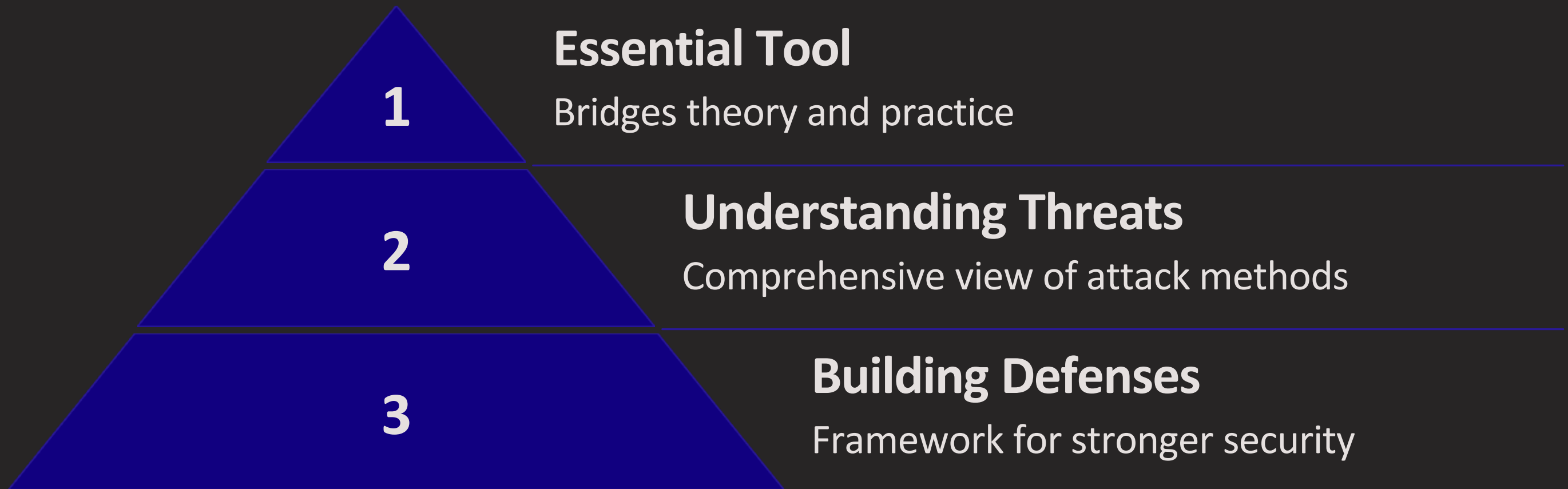
ATLAS > raising awareness of the rapidly evolving vulnerabilities of
vulnerabilities of

AI-enabled systems as they extend beyond cyber.

<https://atlas.mitre.org/>

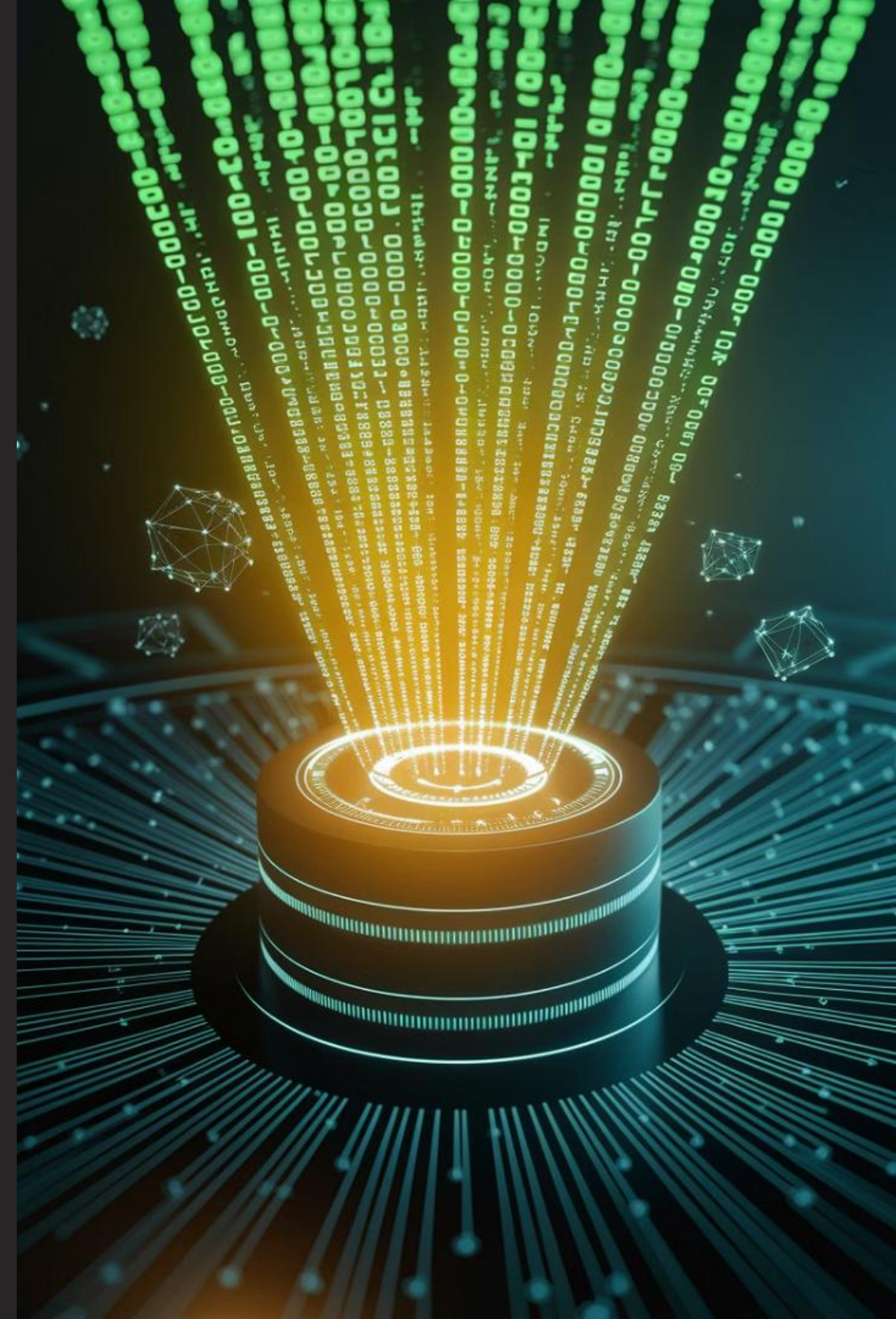
/

Conclusion on MITRE ATT&CK Framework



Case Study: Data Exfiltration via SQL Injection with sqlmap

This case study examines a real-world attack scenario where an attacker exploited a SQL injection vulnerability in a retail website. We'll analyze the attack methodology, tools used, and defensive countermeasures.





Attack Scenario Overview

The Target

Small online retailer with a vulnerable product search feature. The web application allows customers to browse products and manage accounts.

The Vulnerability

SQL Injection flaw in the input boxes functionality. Lack of proper input validation creates a security gap.

The Attack

Attacker uses **sqlmap** to automate exploitation. Customer's usernames, emails, and hashed passwords are extracted.



Vulnerability Discovery Phase



Identifying the Target

Attacker searches for potential potential entry points in the web web application. Focus on user user input fields.



Testing Injection Points

Attacker tests the search parameter with a single quote ('). ('). The application reveals SQL SQL syntax error messages.



Vulnerability Confirmation

Error message confirms the application is passing unfiltered unfiltered input directly to the database query.



redtiger.labs.overthewire.org



Warning: mysql_num_rows() expects parameter 1 to be resource, boolean given in /var/www/html/hackit/level2.php on line 48
Login incorrect!



SQL Injection Attacks

SQL Injection is a dangerous vulnerability that allows attackers to manipulate database queries through malicious input. The consequences can be severe for organizations and their users.



How SQL Injection Works

1

Vulnerable Code

Applications build SQL queries by directly including including user input without proper validation.

2

Malicious Input

Attackers insert code like '**OR '1'='1'** --' into input fields.

3

Query Manipulation

The input transforms the original query logic, logic, bypassing authentication or extracting data. extracting data.

Types of SQL Injection Attacks

Error-based

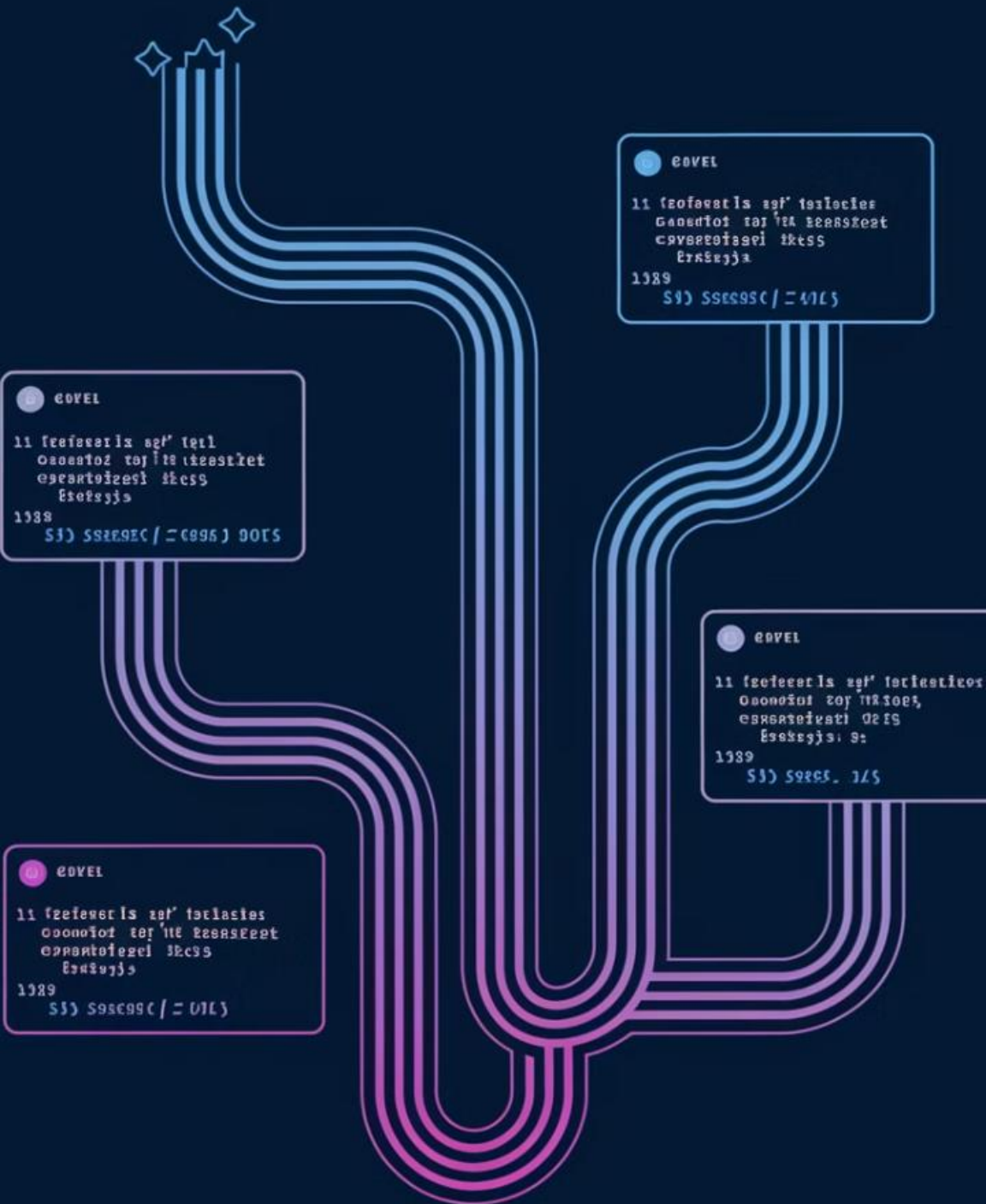
Exploits database error messages to learn about database structure. Attackers trigger errors to reveal information.

Union-based

Uses the UNION operator to combine results with attacker's query. Enables direct extraction of sensitive data.

Blind

Works when errors are hidden. Attackers observe application behavior to infer database information.



Resources

portswigger.net> <https://portswigger.net/web-security/sql-injection>

tryhackme.com> <https://tryhackme.com/room/sqlinjectionlm>

hackthebox.com> <https://academy.hackthebox.com/module/details/33>

Data Exfiltration with **sqlmap**

1

Automated SQL Injection Tool

sqlmap is an open-source penetration testing tool that automates the detection and exploitation of SQL injection vulnerabilities.

2

Advanced Capabilities

Performs database fingerprinting, password hash cracking, and privilege escalation with minimal user input.

3

Database Enumeration

Extracts schema information, tables, columns, and dumps sensitive data from vulnerable applications.

4

Command Execution

Can escalate attacks to execute operating system commands through database procedures on compromised servers.

5



sqlmap: automatic SQL injection and database takeover t...

sqlmap is an open source penetration testing tool that automates the process of detecting and exploiting SQL injection flaws and taking over of database servers. It comes with a powerful detection engine, many niche features for the ultimate penetration tester...

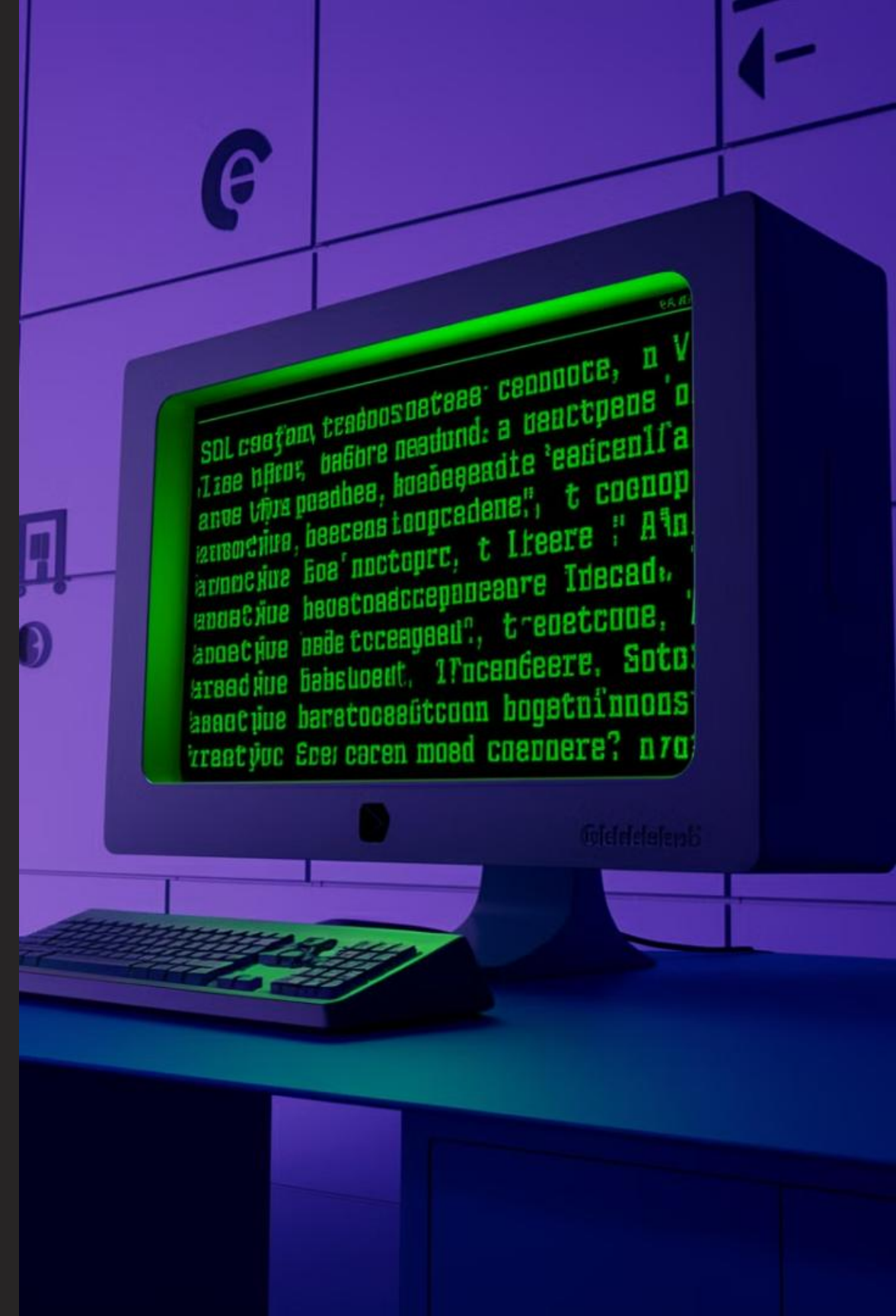


Technical Exploitation with **sqlmap**

Analyze for SQL Injection

Attacker runs sqlmap with command:

```
sqlmap -u  
"https://redtiger.labs.overthewire.org/level1.php?cat=1"
```



Technical Exploitation with sqlmap

Database Enumeration

Attacker runs sqlmap with command:

```
sqlmap -u "https://redtiger.labs.overthewire.org/level1.php?cat=1" --technique=U --dbs
```

This reveals all available databases on the server.

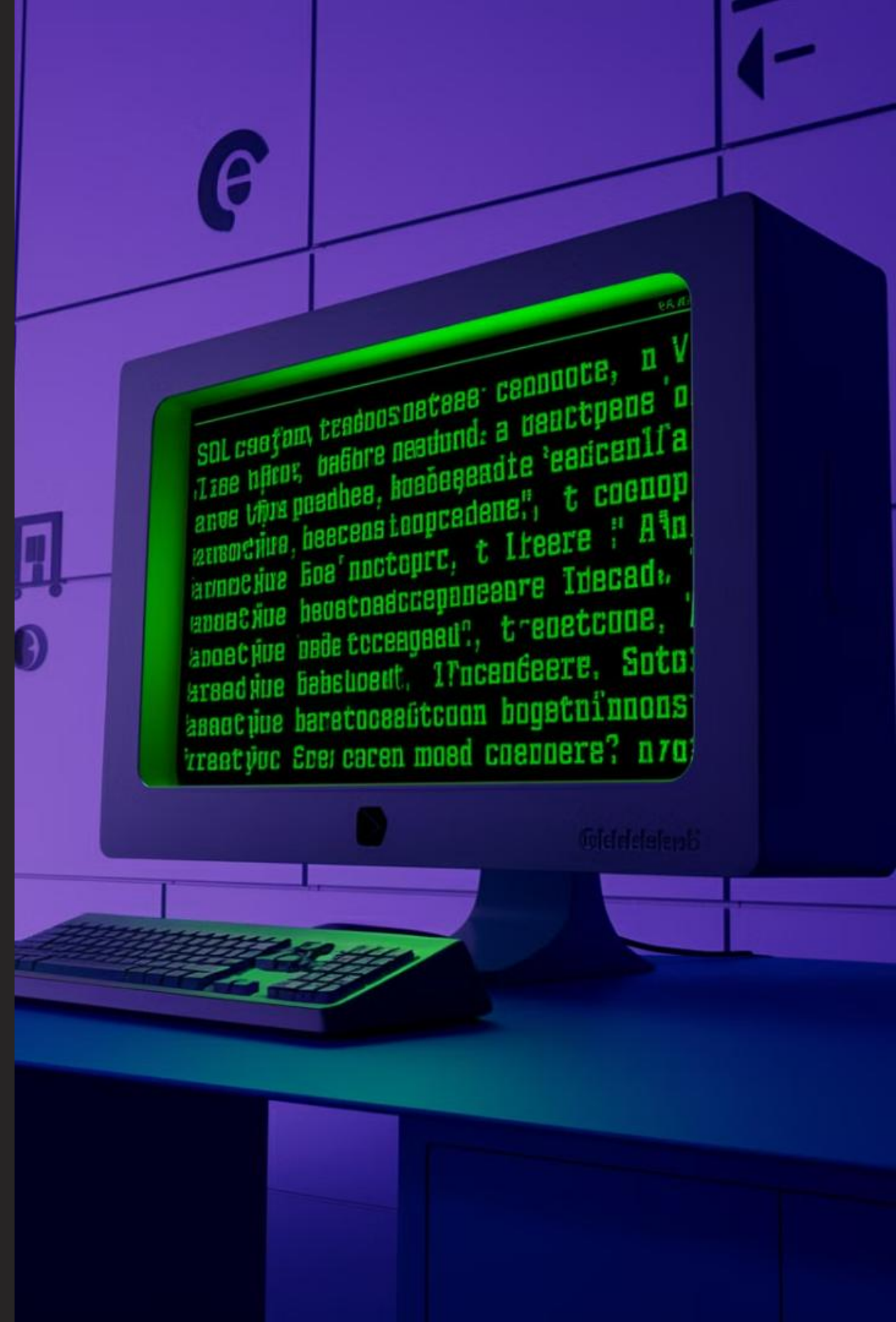
Target Selection

After identifying databases, attacker targets the database specifically.

Data Extraction

Complete dump executed with:

```
sqlmap -u  
"https://redtiger.labs.overthewire.org/level1.php?ca  
t=1" -D hackit -T level1_users --dump --level=5 --  
risk=3
```

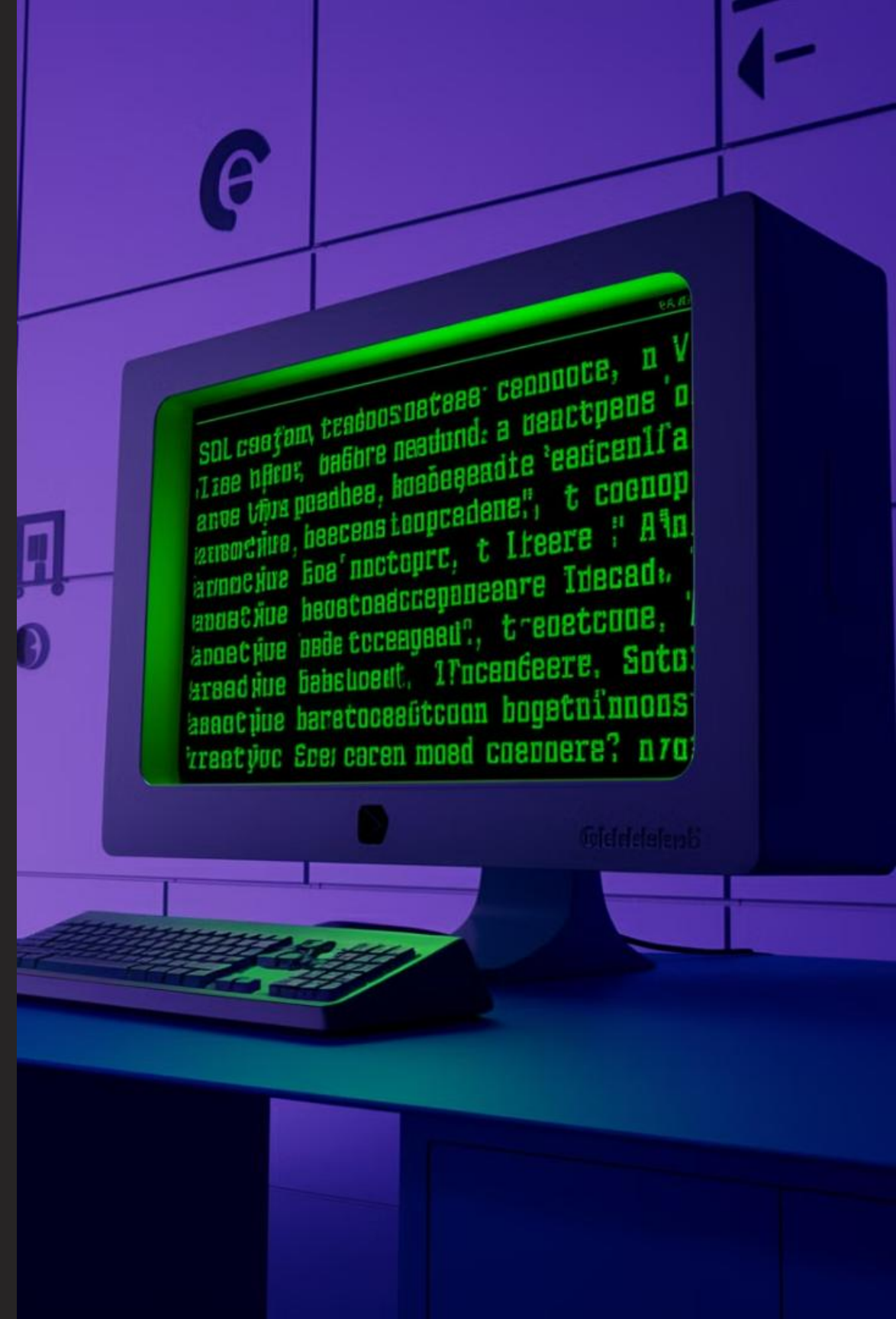


Technical Exploitation with **sqlmap**

User Data Extraction/Exfiltration

Attacker runs command:

```
https://redtiger.labs.overthewire.org/level1.php?cat=1+U  
NION+SELECT+NULL,NULL,username,password+FROM+level1_user  
S--
```

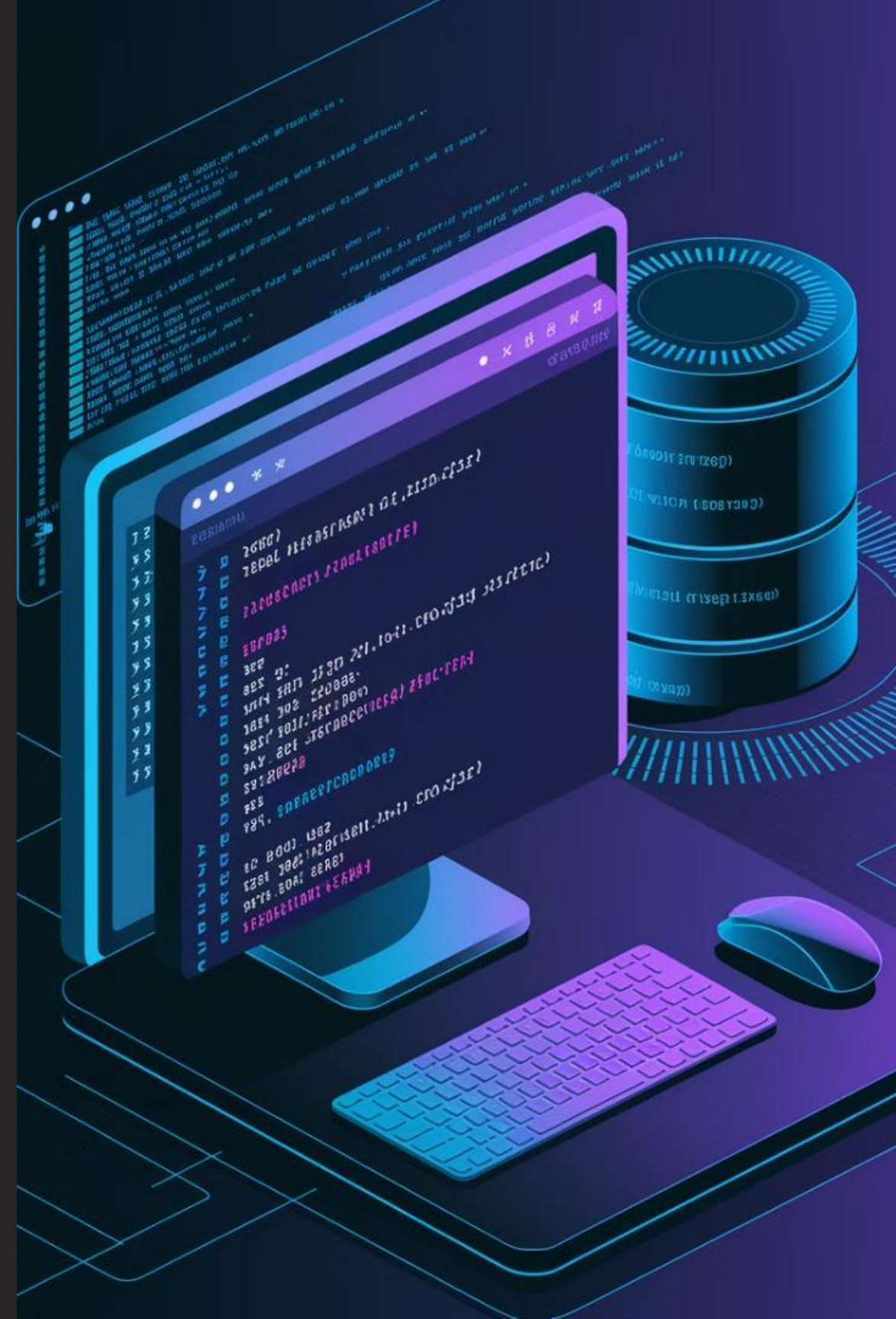


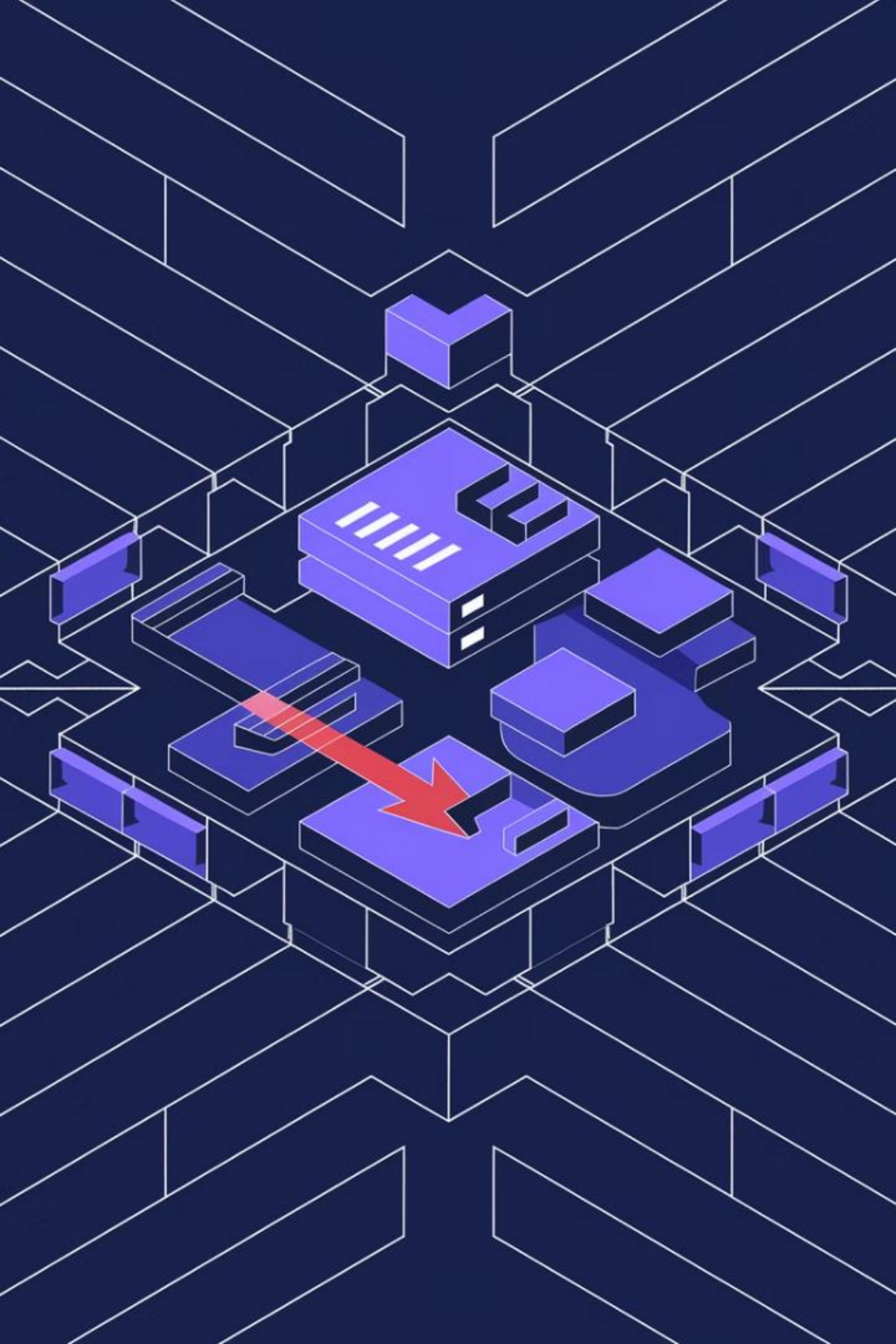
SQL Injection > Vulnerabilities

Vulnerabilities Assessment

```
sqlmap -u "https://feaa.uvt.ro/ro/studenti/avizier-general\*/"
```

```
sqlmap -u "https://feaa.uvt.ro/ro/studenti/avizier-general\*/" --level 5
```





MITRE ATT&CK: Initial Access

1

Technique Analysis

T1190: Exploit Public-Facing Application. This technique exploits vulnerabilities in internet-facing systems.

2

Implementation

Attacker targets the web application's search feature. The vulnerable parameter becomes the entry point.

3

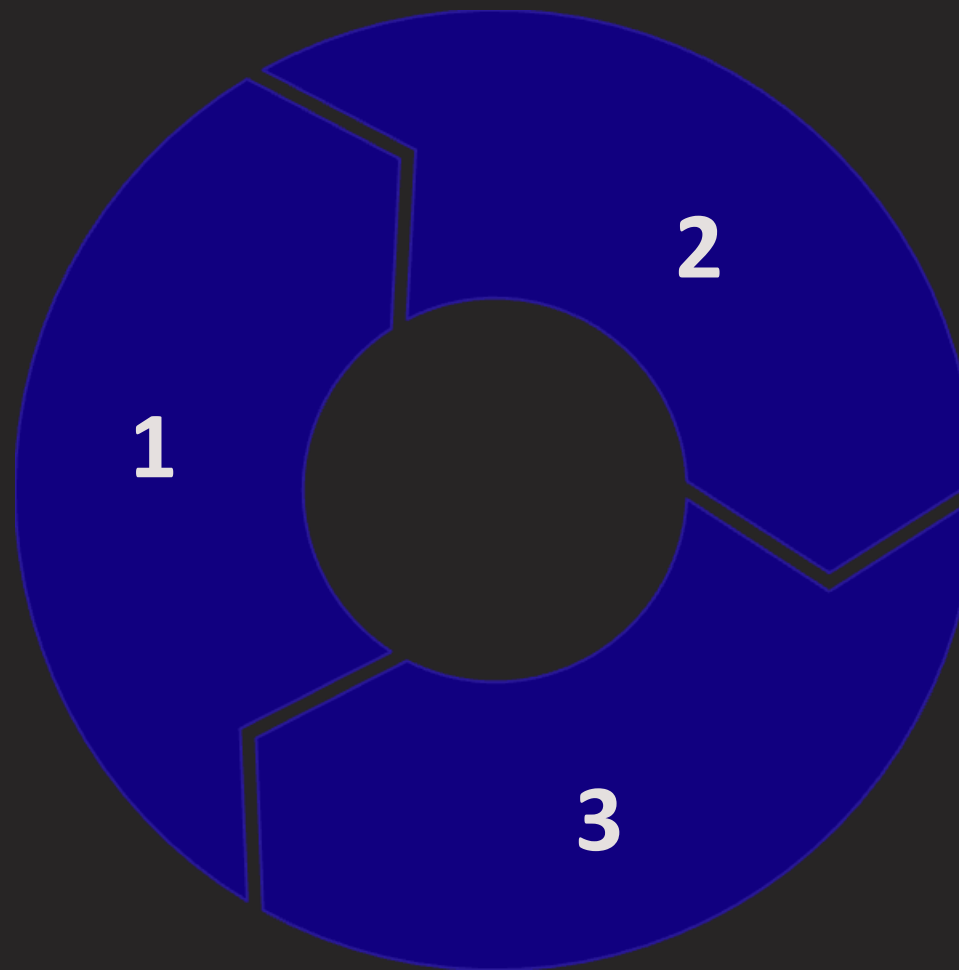
Impact

Successful exploitation grants unauthorized access to the the backend database. No authentication barriers were overcome.

MITRE ATT&CK: Collection

Technique Identification

T1005: Data from Local System. System. This involves gathering gathered stored data from targeted systems.



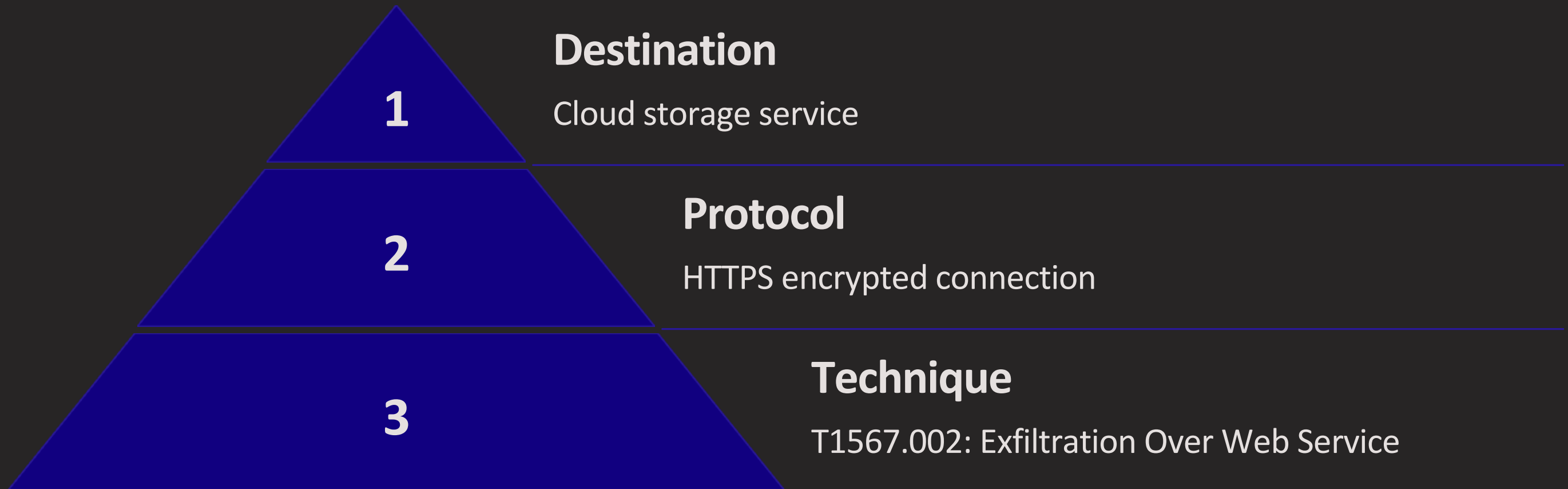
Automation Aspects

sqlmap handles technical complexities. It automates database schema discovery and and data extraction.

Data Targeting

Tool focuses on valuable information. Usernames, emails, emails, and password hashes hashes are primary targets.

MITRE ATT&CK: Exfiltration



This technique leverages legitimate web services as exfiltration channels. Using common protocols helps attackers avoid detection by blending with normal traffic patterns.

Detection and Response Strategies

Attack Indicators

- Suspicious web server logs with UNION SELECT SELECT statements
- Unusual query patterns to search endpoint

Response Actions

- Implement parameterized queries (<https://www.php.net/manual/en/pdo.prepared-statement.php>)
- Block malicious IP addresses
- Scan for additional compromises



Key Security Takeaways

Persistent Threat Vector

SQL Injection remains dangerous despite being well-documented. Proper input validation is essential for all user-supplied data.

Democratized Attack Tools Tools

Tools like sqlmap lower the technical barrier. Even less skilled attackers can execute sophisticated exploits.

Exfiltration

Data theft can happen quietly. Proactive monitoring of traffic and logs is crucial for early detection.



Lessons Learned and Mitigation Strategies

Strategies



Input Validation

Implement strict input validation on all user-supplied data. Reject any input containing suspicious SQL characters.



Least Privilege

Database accounts should have minimal permissions. Limit what what compromised credentials can access.



Parameterized Queries

Use prepared statements and parameterized queries. This separates SQL code from data inputs.



Regular Testing

Conduct periodic security assessments. Use tools like SQLMap ethically to test your own applications.